

## Table of Contents

|                                                        |          |
|--------------------------------------------------------|----------|
| <b>A. Scenario Overview .....</b>                      | <b>2</b> |
| <b>B. Scenario.....</b>                                | <b>2</b> |
| <b>C. Identified Issue.....</b>                        | <b>2</b> |
| <b>D. Define Objectives .....</b>                      | <b>2</b> |
| <b>E. Select Participants.....</b>                     | <b>2</b> |
| <b>F. Create Injects.....</b>                          | <b>3</b> |
| <b>G. Simulation of scenario .....</b>                 | <b>3</b> |
| <b>Phase 1: Initial Infection.....</b>                 | <b>3</b> |
| <b>Phase 2: Escalation &amp; Impact .....</b>          | <b>4</b> |
| <b>Phase 3: Decision Time .....</b>                    | <b>4</b> |
| <b>Phase 4: Public &amp; Regulatory Response .....</b> | <b>4</b> |
| <b>Phase 5: Recovery &amp; Backup .....</b>            | <b>4</b> |
| <b>H. Post Review Discussion.....</b>                  | <b>4</b> |

# **Tabletop Exercise for a Ransomware attack delivered via a phishing email**

## **A. Scenario Overview**

- **Date:** 1st August 2025
- **Setting:** Normal business day in a financial services organization
- **Trigger:** Employee downloaded and opened a malicious document in a phishing email, initiating a ransomware infection across the network

## **B. Scenario**

A user has just received an email claiming that all employees need to fill a form to update their personal information. Opening the attachment triggered the delivery of a malicious payload that spread through the user's computer and infected several other crucial endpoints including servers within the organization's network. This scenario is based on how an organization would detect, respond and contain a phishing attack that leads to a ransomware infection.

## **C. Identified Issue**

Employees in different departments report being unable to open files. System Admins are unable to access servers. IT Help Desk receives multiple calls about inaccessible systems. There is a ransom note demanding payment to be made in Bitcoin of \$1M or private confidential customer and organization data will be sold and released to the public. There is a sense of urgency due to regulatory notification deadlines.

## **D. Define Objectives**

- Test the incident response plan
- Assess internal and external communication protocols
- Identify gaps in the IRP and assess decision-making within tight timelines
- Validate the effectiveness, currency and efficiency of existing playbooks and escalation procedures
- Test coordination and collaboration across departments during an incident

## **E. Select Participants**

- CISO
- IRP Team
- CSIRT/ Seurity Team
- Legal & Compliance
- Communications
- BCP Lead
- Executive Leadership

## **F. Create Injects**

**Injects** – Information provided to participants to shed light into the scenario

For this case:

- Email sent to the user
- SIEM alert: “Unusual file encryption activity from USER\_LAPTOP1”
- XDR alert
- DLP system alert: “Large outbound data transfer detected”
- IPS : “Outbound communication detected”
- Ransom note
- Behaviour of files when users try to access

## **G. Simulation of scenario**

### **Phase 1: Initial Infection**

#### **Discussion:**

1. As part of the defense-in-depth approach, what mechanisms have been put in place to make it difficult for attackers to reach users?
  - User training on social engineering attacks as users are the weakest link. Documented procedures on reporting if a user suspects an email is malicious.
  - Email filtering software to scan the contents of emails before delivery to user
  - DLP system to prevent the loss of confidential information
  - NIPS system to detect, block and prevent intrusion attempts
  - XDR to detect and prevent intrusions at different levels including cloud, endpoints and provide a broader and holistic security posture. Prevent unauthorized software from running in endpoints
  - Role -based access controls. Limit administrator privileges to system admins
  - PAM access control to log access and operations being performed on systems
  - File Integrity Monitoring to continuously monitor critical files, folders and system configs for unauthorized changes like encryption patterns
2. Who is the first point of contact?
  - Security department – Check if there is an ongoing attack
  - IT infrastructure department – Check if there are any changes, updates or downtimes
3. What immediate actions are taken?
  - Check SIEM for any alerts related to the incident. IOCs like malicious IPs or URLs, unknown processes running on servers, unknown files in shared folders.
  - Check if EDR has flagged the incident on the user’s endpoint
  - Isolate the endpoints infected to prevent malware from spreading
  - NIPS logs for any lateral movements
  - Check firewall logs

## **Phase 2: Escalation & Impact**

4. How is the incident escalated?
  - Classify the risk posed by the incident. Categorize incident as a potential ransomware attack
  - Initiate the Incident Response Plan
  - Notify stakeholders, CISO and IRP team
  - Declare severity of incident
  - Legal obligations to report to CBK and ODPC if containing private data
5. Which systems are affected?
  - Containment strategy. Check systems malware has spread to and ensure malware is not spreading
  - Rank affected systems based on criticality to the continuity of business operations
  - Check the importance of encrypted documents

## **Phase 3: Decision Time**

- Consideration to pay ransom
- Involving different stakeholders in the decision – Who makes the decision? Who is consulted? Criteria to pay or not?
- Consideration of implications of paying or not paying ransom

## **Phase 4: Public & Regulatory Response**

- Drafting of internal and external communication to media, customers, staff, partners
- Confirm existence and relevance of a communication plan that is executed in the event of a cyber incident
- Informing external regulators within prescribed period in case of a breach i.e inform CBK, ODPC
- Deciding on communication channels, person responsible for communication, amount of detail to disclose

## **Phase 5: Recovery & Backup**

- BCP & DRP Plan – Ensure business continuity. Check if backups and downtimes are within RTO & RPO and if the backup plan is up to date, reviewed and tested.
- Determine impact on normal operations and availability of alternative systems that can be used until recovery
- Determine if backups are separate to normal business systems to ensure backups are available and not encrypted.

## **H. Post Review Discussion**

- Decide what went well
- Note and document areas that need improvement. Identify process gaps
- Determine if all stakeholders understand their roles and provide clarifications
- Check effectiveness of communication channels
- Determine effectiveness of existing controls